

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

RESPUESTA INCIENTE

La continuidad de la competencia

Manual de Gestor Práctica y Analista Junior

TEN Lo que este manual hace: Muestra cómo prepararse para la perturbación, detectar y gestionar incidentes cibernéticos, continuar servicios críticos, restaurar la tecnología de forma segura, probar pruebas, utilizar herramientas de código abierto y crear habilidades de analista orientadas al trabajo. | |.

Alberto (Al) Leiva

Primera edición • Julio 2026

Prefacio

Los incidentes y las interrupciones no siguen un script conveniente. Un ciberataque puede convertirse en una crisis legal, de seguridad, cliente, financiera, operativa y de reputación. Buena resiliencia conecta la respuesta a incidentes, continuidad de las operaciones, recuperación en casos de desastre, liderazgo en crisis, comunicaciones, proveedores y mejora continua.

Este manual utiliza lenguaje simple y productos de trabajo realistas. No es asesoramiento legal ni garantía. Las necesidades varían por organización, sector, contrato, país, regulador, tecnología y evento. Durante una emergencia real, siga la autoridad aprobada, mantenga la seguridad y las pruebas, e involucre a profesionales jurídicos, de privacidad, de recursos humanos, comunicaciones, seguros, encargados de hacer cumplir la ley y técnicos, según proceda.

**** Nota de información actual**** La orientación oficial fue verificada el 14 de julio de 2026. La fundación responsable de incidentes es NIST SP 800-61 Rev. 3, finalizado el 3 de abril de 2025. El contenido de continuidad también utiliza NIST SP 800-34 Rev. 1 Update 1 y ISO 22301:2019 con la enmienda 1:2024. |

|.

Cómo usar este manual

- Gerentes: comiencen con los Capítulos 1–5, 7, 9–13, 19–25 y 27.

- Analistas junior: estudiar en orden y completar Capítulos 26–29 con datos sintéticos y laboratorios autorizados.
- Respuestas técnicas: enfoque en los capítulos 5–18, 21–24 y 26.
- Equipos de continuidad y recuperación: enfoque en los capítulos 3, 11, y 19-24.
- Adaptar cada plan, umbral, contacto, requisito y ejercicio a la organización.

Tabla de contenidos

Este documento contiene una tabla de contenidos de Word nativa. La guía del capítulo en la siguiente página es una referencia rápida permanente.

[Prefacio \[2\] \(#preface\)](#)

[Cómo utilizar este manual \[2\] \(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[3\] \(#table-of-contents\)](#)

[Guía de cambio \[7\]\(#chapter-guide\)](#)

[1. IR, Business Continuity, and Disaster Recovery Foundations \[8\]\(#ir-business-continuity-and-disaster-recovery-foundations\)](#)

[2. Gobernanza, política y funciones \[9\]\(#governance-policy-and-roles\)](#)

[2.1 Es esencial para la gobernanza \[9\]\(#governance-essentials\)](#)

[3. Risk Assessment and Business Impact Analysis \[10\]\(#risk-assessment-and-business-impact-analysis\)](#)

[3.1 Método BIA \[10\]\(#bia-method\)](#)

[4. Modelo actual de respuesta de incidentes NIST \[12\]\(#current-nist-incident-response-model\)](#)

[4.1 Secuencia operacional práctica \[12\]\(#practical-operating-sequence\)](#)

[5. Preparación y preparación \[13\]\(#preparation-and-readiness\)](#)

[5.1 Lista de verificación para la lectura \[13\]\(#readiness-checklist\)](#)

[5.2 Diseño de Playbook \[13\]\(#playbook-design\)](#)

[6. Detección y validación de eventos \[14\]\(#detection-and-event-validation\)](#)

[6.1 Fuentes de señal \[14\]\(#signal-sources\)](#)

[6.2 Preguntas de validación \[14\]\(#validation-questions\)](#)

[7. Triage, Severity, and Escalation \[15\]\(#triage-severity-and-escalation\)](#)

[7.1 Producción de triage \[15\]\(#triage-output\)](#)

- 8. Investigation and Scoping [16](#investigation-and-scoping)
 - 8.1 Método de investigación [16](#investigation-method)
- 9. Estrategia de Contención [17](#containment-strategy)
 - 9.1 Opciones [17](#options)
 - 9.2 Registro de decisiones [17](#decision-record)
- 10. Erradicación y Remediación [18](#eradication-and-remediation)
 - 10.1 Erradicación [18](#eradication-work)
- 11. Recuperación y regreso al servicio [19](#recovery-and-return-to-service)
 - 11.1 Puertas de recuperación [19](#recovery-gates)
 - 11.2 Pruebas de recuperación [19](#recovery-evidence)
- 12. Lecciones Aprendidas y Mejoras [20](#lessons-learned-and-improvement)
 - 12.1 Proceso de acción posterior [20](#after-action-process)
- 13. Coordinación de comunicaciones, jurídicas y reglamentarias [21](#communication-legal-and-regulatory-coordination)
 - 13.1 Reglas de funcionamiento [21](#operating-rules)
- 14. Evidencia digital y preparación forense [22](#digital-evidence-and-forensic-readiness)
 - 14.1 Evidencia [22](#evidence-record)
- 15. Ataques Ransomware y Destructivos [23](#ransomware-and-destructive-attacks)
 - 15.1 Prioridades inmediatas [23](#immediate-priorities)
 - 15.2 Decisión de pago [23](#payment-decision)
- 16. Respuesta del incidente de Cloud and SaaS [24](#cloud-and-saas-incident-response)
 - 16.1 Investigación en la nube [24](#cloud-investigation)
 - 16.2 Contención en la nube [24](#cloud-containment)
- 17. Identidad y Acceso Privilegiado [25](#identity-and-privileged-access-incidents)
 - 17.1 Ámbito [25](#scope)
 - 17.2 Orden de recuperación segura [25](#safe-recovery-order)
- 18. Third-Party and Supply-Chain Incidents [26](#third-party-and-supply-chain-incidents)
 - 18.1 Preparar [26](#prepare)
 - 18.2 Responder [26](#respond)

- 19. Business Continuity Management System [27](#business-continuity-management-system)
- 20. Estrategias y procedimientos de continuidad [28](#continuity-strategies-and-procedures)
 - 20.1 Procedimiento de continuidad [28](#continuity-procedure)
- 21. Planificación de la recuperación de desastres [29](#disaster-recovery-planning)
 - 21.1 NIST SP 800-34 proceso de contingencia [29](#nist-sp-800-34-contingency-process)
 - 21.2 Contenido del plan DR [29](#dr-plan-content)
- 22. Backups and Recovery Assurance [30](#backups-and-recovery-assurance)
 - 22.1 Diseño [30](#design)
 - 22.2 Prueba de restauración [30](#restore-test)
- 23. Gestión de crisis y factores humanos [31](#crisis-management-and-human-factors)
 - 23.1 Ritmo de liderazgo [31](#leadership-rhythm)
- 24. Ejercicios, capacitación y mantenimiento del plan [32](#exercises-training-and-plan-maintenance)
 - 24.1 Pruebas posteriores a la acción [32](#after-action-evidence)
- 25. Mapeo de cumplimiento, pruebas de evidencia y métricas [33](#compliance-mapping-evidence-testing-and-metrics)
 - 25.1 Prueba de prueba [33](#evidence-test)
- 26. Herramientas de código abierto [34](#open-source-tools)
 - 26.1 TheHive [34](#thehive)
 - 26.2 Cortex [34](#cortex)
 - 26.3 MISP [35](#misp)
 - 26.4 Wazuh [35](#wazuh)
 - 26.5 Velociraptor [35](#velociraptor)
 - 26.6 Volatilidad 3 [35](#volatility-3)
 - 26.7 Autopsia [35](#autopsy)
 - 26.8 Timesketch [36](#timesketch)
 - 26.9 Plaso / log2timeline [36](#plaso-log2timeline)
 - 26.10 osquery [36](#osquery)
 - 26.11 Zeek [36](#zeek)

26.12 Suricata [36](#suricata)

26.13 YARA [37](#yara)

26.14 Sigma [37](#sigma)

26.15 DFIR-IRIS [37](#dfir-iris)

26.16 GRR Rapid Response [37](#grr-rapid-response)

26.17 Shuffle [38](#shuffle)

26.18 OpenSearch [38](#opensearch)

27. Manual de resiliencia para gerentes [39](#managers-resilience-playbook)

27.1 Cuestiones ejecutivas [39](#executive-questions)

28. Junior Analyst Career Guide and Portfolio Lab [40](#junior-analyst-career-guide-and-portfolio-lab)

28.1 Funciones comunes [40](#common-roles)

28.2 Trabajo típico [40](#typical-work)

28.3 Fictional portfolio lab [41](#fictional-portfolio-lab)

29. Preparación del Plan de Treinta Días y la Entrevista [42](#thirty-day-plan-and-interview-preparation)

29.2 ¿Cuál es la diferencia entre IR, BC y DR? [42](#what-is-the-difference-between-ir-bc-and-dr)

29.3 ¿Qué es NIST SP 800-61 Rev. 3? [42](#what-is-nist-sp-800-61-rev.-3)

29.4 RTO versus RPO? [42](#rto-versus-rpo)

29.5 ¿Cómo se recorta un incidente? [42](#how-do-you-triage-an-incident)

29.6 ¿Qué hace la evidencia confiable? [42](#what-makes-evidence-reliable)

29.7 ¿Cuándo se completa la recuperación? [42](#when-is-recovery-complete)

29.8 ¿Cómo se cierra una mejora? [42](#how-do-you-close-an-improvement)

29.9 ¿Qué debe evitar un analista junior? [43](#what-should-a-junior-analyst-avoid)

29.10 Preguntas para hacer al empleador [43](#questions-to-ask-the-employer)

30. Plantillas, Glosario, Índice y Referencias [44](#templates-glossary-index-and-references)

30.1 Registro de casos de incidentes [44](#incident-case-record)

30.2 AII y registro de continuidad [44](#bia-and-continuity-record)

30.3 Evidencia y registro de cadena de custodia [44] (#evidence-and-chain-of-custody-record)

[30.4 Registro de ejercicio y acción correctiva \[44\]\(#exercise-and-corrective-action-record\)](#)

[30.5 Glosario \[45\]\(#glossary\)](#)

[30.6 Índice de asunto \[45\]\(#subject-index\)](#)

[30.7 Referencias oficiales \[46\]\(#official-references\)](#)

Guía del Capítulo

Capítulo

– IR, Business Continuity, and Disaster Recovery Foundations | 2 | Gobernanza, Política y Roles | 6 Silencioso 3 Evaluación de Riesgos y Análisis de Impacto Empresarial | 4 | actual NIST Respuesta del incidente Modelo | 9 | 5 – Preparación y Lecturas | 6 | Detección y Validación de Eventos | 7 – Triage, Severity, and Escalation | 8 Silenciosos de investigación y desarrollo | Silenciosos 9 Silenciosos Estrategia de Contención Silenciosos 10 Silenciosos Erradicación y Remediación | 11 Silencioso de recuperación y regreso al servicio | tención 12 lecciones aprendidas y mejoradas | 13 | Comunicación, Coordinación Jurídica y Reguladora | 14 | Evidencia Digital y Lecturas Forenses | 15 | Ransomware and Destructive Attacks | 16 | en la nube y SaaS Respuesta del incidente TEN 17 | Identidad y Acceso Privilegiado Incidentes | 22 | tención 18 Silenciosos Incidentes de Terceros y Cambios de Suministros | 19 | Business Continuity Management System | 20 | Estrategias y Procedimientos de Continuidad | 21 | para la recuperación de desastres Silenciosos y seguridad de la recuperación Silencioso en la gestión de crisis y los factores humanos | 24 | Ejercicios, Capacitación y Mantenimiento del Plan | 30 TENCIÓN 25 | Cumplimiento de Mapping, Pruebas de Evidencia y métricas | 26 | Open-Source Herramientas | 32 | Resilience Playbook de Resilience Manager Silencioso | 28 | Junior Analyst Guía de Carreras y Portfolio Lab | 29 | Plan de Treinta Días y Preparación de Entrevista | 30 TENIDOS Plantillas, Glosario, Índice y Referencias | 42 |

1. IR, Business Continuity, and Disaster Recovery Foundations

Resilience conecta la respuesta cibernética, operaciones críticas, restauración tecnológica y liderazgo.

■img src="media/image1.png" estilo="Ancho:6.15in; Altura:3.39605in" alt="Govern, Identificar y Proteger la preparación de soporte; Detectar, Responder y Recuperar incidentes de manija; las lecciones mejorar cada función." /

Gráfico 1 Ciclo integrado de resiliencia cibernética

Capacidad Silencioso ** Pregunta primaria** |————— La vida ————— | Respuesta del incidente | ¿Cómo detectamos, conteniendo, eliminamos, recuperamos y aprendemos de incidentes cibernéticos? | Seguridad / Comandante del incidente ¿Cómo continuarán los productos y servicios críticos durante la interrupción? continuidad de las operaciones / propietarios de procesos ¿Cómo se restaurarán la tecnología y los datos a los objetivos aprobados? viv IT / sistema y propietarios de recuperación ¿Cómo los líderes tomarán decisiones de alto impacto y coordinarán a los interesados? equipo de crisis ejecutiva | de

emergencia / seguridad de la vida | ¿Cómo se protegerá a la gente durante el peligro físico?
instalaciones / seguridad / autoridades públicas

No confundan los planes** Deben coordinarse, pero tienen diferentes objetivos, autoridades, desencadenantes, equipos y pruebas. Un documento rara vez sirve a cada necesidad bien. |
Respuesta

2. Gobernanza, política y funciones

La austeridad, los derechos de decisión, los contactos y los recursos deben existir antes de que comience la presión.

2.1 Gobernanza esencial

- Política, alcance, objetivos, autoridades, criterios de riesgo y recursos aprobados por el Ejecutivo.
- Nombrado comandante de incidentes, líder técnico, líder de continuidad, líder de recuperación, líder de comunicaciones, contactos legales/privacy y suplentes.
- umbrales de severidad y activación, rutas de escalada, autoridad de cambio de emergencia, autoridad de gasto y aceptación de riesgos comerciales.
- Métodos de contacto seguros, comunicaciones fuera de banda, árboles de llamada, proveedores, aseguradores, reguladores y autoridades públicas.
- Plan de propiedad, control de versiones, distribución, capacitación, ejercicio, revisión y calendario de mejora.

Rol

Comandante de incidentes

TENCIÓN Líder técnico permanente Investigación, alcance, contención, erradicación, criterios de recuperación | Propietario de negocios | Impacto operacional, solución de trabajo, prioridad, aceptación de regreso al servicio | — Continuidad / liderato de la RD | Procesos alternativos/sitio, secuencia de recuperación, conflictos de recursos TEN Legal / privacy TENCIÓN Privilege, preservación, análisis de notificaciones, autoridades, contratos | Comunicaciones | Empleados, clientes, socios, publico, medios de comunicación, aprobación de mensajes — Scribe / evidencia custodia tención Timeline, decisions, evidence identity, custody, action log | Equipo de crisis ejecutiva Seguridad, riesgo material, estrategia, recursos, postura externa |

3. Evaluación de riesgos y análisis de impacto empresarial

Un análisis de impacto empresarial convierte la importancia vaga en requisitos de recuperación basados en el tiempo.

“Estilo del anzuelo” = “Análisis” = ancho:6.15in; altura:3.39605in” alt=“Analyze impactantes antes de elegir la tecnología o soluciones de continuidad.” /

Figure 2. BIA reasoning chain

3.1 BIA method

- Definir productos, servicios, procesos, propietarios, clientes y productos mínimo aceptables.
- Estimar la seguridad, legal, cliente, financiero, operativo, privacidad, seguridad y el impacto de reputación a medida que aumenta la longitud de la perturbación.
- Establecer el período máximo tolerable de perturbación (MTPD/MAO) y un objetivo de tiempo de recuperación (RTO) que se ajuste dentro de él.
- Establecer el objetivo del punto de recuperación (RPO): la pérdida máxima de datos tolerables medida en el tiempo.
- Identificar a personas, instalaciones, tecnología, datos, proveedores, servicios públicos, comunicaciones, registros y dependencias de corriente y corriente.
- Validar supuestos con los propietarios de procesos y el liderazgo; resolver prioridades conflictivas.
- Use resultados para seleccionar estrategias, niveles de recuperación, pruebas, inversiones y contenido del plan.

**** Term ****

MTPD / MAO

— RTO

RPO

Nivel mínimo de servicio

tención dependencia tención Recurso otro proceso necesita para entregar su salida TENSE
Identidad, DNS, región de la nube, personas, proveedor

Error común: ** RTO y RPO son requisitos de negocio, no ajustes de producto de copia de seguridad. Pruebe si el servicio completo al final puede realmente satisfacerlos. | | |

4. Actual NIST Modelo de respuesta de incidentes

NIST SP 800-61 Rev. 3 integra la respuesta de incidentes en las seis Funciones CSF 2.0.

CSF Función | **** Contribución de respuesta a los incidentes ****

|. | tención Govern Silencioso política, funciones, autoridades, necesidades legales y contractuales, responsabilidades de proveedores, supervisión, mejora tención Identificar activos, servicios, datos, dependencias, riesgos, vulnerabilidades, necesidades de mejora Ø Proteger la identidad, configuración, conciencia, seguridad de datos, mantenimiento, resiliencia, tecnología de protección — Detectar | Monitorización continua y análisis de eventos adversos Respuesta a la respuesta Silencioso Gestión de incidentes, análisis,

informes/comunicaciones, mitigación y Recuperar la ejecución del plan de recuperación, restauración, verificación y comunicación de recuperación

Lo que cambió de Rev. 2: ** El diagrama de preparación, detección/análisis más antiguo–contenimiento/eradicación/recuperación–post-incidente sigue siendo útil operacionalmente, pero el Rev. 3 supera a Rev. 2 y enmarca la respuesta como gestión del riesgo de ciberseguridad en toda la organización. | Respuesta

4.1 Secuencia operativa práctica

- Prepararse continuamente mediante la gobernanza, la identificación y la protección.
- Detectar un posible evento adverso y validarlo.
- Administrar, analizar, comunicar, contener y mitigar el incidente.
- Restaurar con seguridad y comunicar recuperación.
- Captar lecciones y mejorar las seis Funciones.

5. Preparación y preparación

La preparación reduce la confusión, los fallos de acceso, la pérdida de evidencia y la improvisación peligrosa.

5.1 Lista de verificación de la luminosidad

- Activo actual, identidad, datos, aplicación, proveedor, fuente de registro e inventarios de dependencia.
- Planes protegidos, contactos sin conexión, diagramas, credenciales, kits de salto, herramientas forenses, dispositivos limpios, licencias y comunicaciones seguras.
- Sincronización del tiempo central, registro suficiente, telemetría de endpoint/network/cloud, cobertura de detección, retención y acceso probado.
- Acciones de contención aprobadas, cambios de emergencia, métodos de aislamiento, suspensión de cuentas, rotación de token/key, bloqueo de dominios y criterios de cierre del sistema.
- Conservación de pruebas, privacidad, retención legal, cadena de custodia, aseguradora, cumplimiento de leyes y procedimientos de notificación.
- Imágenes bien conocidas, proceso de construcción seguro, respaldos protegidos, orden de restauración, criterios de validación y aceptación empresarial.
- Entrenamiento de roles, mesa de mesa y ejercicios técnicos, pruebas de call-tree y mejoras rastreadas.

5.2 Diseño del manual de respuesta

**

Silencioso Trigger

tención de objetivos Lo que debe ser protegido o aprendido – Autoridad | Quién puede aprobar acciones disruptivas tención Pasos Silenciosos Puntos de decisión, acciones, dependencias y alternativas seguras – Evidencia voca Qué capturar antes y después de la acción – Comunicación | Audiencia, canal, cadencia, hechos aprobados – Recuperación Silencioso Criterios de entrada, validación, monitoreo, aceptación – Mejoramiento Silencioso , revisión, propietario, retest

6. Detección y validación de eventos

La detección combina tecnología, informes humanos, aviso externo y contexto.

“La señal se convierte en un incidente sólo después de la validación y clasificación bajo criterios aprobados”.

Figura 3. Flujo de trabajo de detección por caso

6.1 Signal sources

- Endpoint, identidad, red, correo electrónico, nube, aplicación, base de datos, pérdida de datos, sistemas físicos, de vulnerabilidad y de inteligencia de amenazas.
- Empleados, clientes, socios, investigadores, proveedores, reguladores, cumplimiento de la ley, aseguradores y proveedores de servicios gestionados.
- Salud de servicio, fraude financiero, actividad de apoyo inusual, cambio de configuración, acción privilegiada y anomalías de calidad de datos.

6.2 Preguntas de validación

- ¿Qué generó exactamente la señal? ¿Es la fuente confiable y sincronizado el tiempo?
- ¿Podría explicarlo el mantenimiento, las pruebas, el comportamiento del usuario o la calidad de los datos?
- ¿Qué usuario, dispositivo, servicio, arrendatario, datos, región o proveedor está afectado?
- ¿Qué evidencia corroborante existe entre fuentes independientes?
- ¿La actividad continúa, difunde, privilegiada, expuesta externamente, destructiva o de seguridad relacionada?
- ¿Qué debe conservarse antes de que una acción de contención cambie las pruebas?

7. Triage, Severity, and Escalation

- El juicio establece prioridad y inicia las vías correctas de autoridad, evidencia y comunicación.*

Silencioso ** Factor de perseverancia** |... | ¿Qué productos, servicios, procesos, personas o resultados de seguridad son afectados? | – Impacto de la información ¿Fue acceso a los datos, cambiado, destruido, expuesto, encriptado o no disponible? viv Recoverability | ¿Puede el problema ser contenido y restaurado con las personas disponibles, el tiempo y los recursos? – Amenaza / persistencia ¿Es el actor activo, privilegiado, destructivo, sofisticado o en movimiento lateralmente? | ¿Cuántos sistemas, identidades, ubicaciones, clientes o proveedores pueden compartir la exposición? Silencioso Obligación / visibilidad ¿Se puede aplicar legal, contractual, regulador, asegurador, cliente o aviso público? ¿Qué hechos faltan, y podrían aumentar significativamente la gravedad?

7.1 Producción de triaje

- identificador de casos, tiempo detectado, tiempo de inicio conocido, reportero, comandante, gravedad, estado y espacio de trabajo seguro.
- Datos actuales separados de supuestos e hipótesis.
- Poblaciones afectadas y potencialmente afectadas, impacto empresarial, evidencia preservada y protección inmediata.
- Tareas, propietarios, plazos, próxima actualización, escalada y relojes de notificación.
- Racionalidad para cambios de gravedad y decisiones importantes.

8. Investigación y exploración

La investigación construye y prueba explicaciones mientras el ambiente y el atacante pueden estar cambiando.

8.1 Método de investigación

- Escribe las preguntas iniciales: punto de entrada, identidad, acción, persistencia, privilegio, movimiento, datos, mando y control, impacto y acceso restante.
- Crear una línea de tiempo y fuente récord de eventos, zona horaria, confianza y brechas.
- Alcance de indicadores conocidos a identidades conexas, anfitriones, recursos en la nube, aplicaciones, datos y proveedores; no dependa de un indicador.
- Preserve evidencia volátil antes de apagarse cuando sea segura, autorizada y útil.
- Prueba las hipótesis competidoras y busca evidencia desconfirmante.
- Método de recogida de documentos, consultas, hashes, versiones, limitaciones y conclusiones analistas.
- Breves tomadores de decisiones con hechos, incertidumbre, efecto empresarial, opciones, y recomendó el próximo paso.

Pregunta |...| ¿Cómo comenzó el acceso? – Correo electrónico, identidad, punto final, web, VPN, nube, vulnerabilidad y registros de soporte | ¿Qué hizo el actor? proceso, comando, audit, archivo, registro, memoria, red y actividad en la nube ¿Qué fue accedido? tención Aplicación, base de datos, objeto, DLP, consulta, API y registros de acceso a archivos ¿Permanece la persistencia? cuentas, fichas, claves, tareas programadas, servicios, aplicaciones OAuth, funciones en la nube ¿Hasta dónde se extendió? gráfico de identidad, consultas de punto final, flujos de red, DNS, acceso remoto, herramientas compartidas ¿Qué se puede confiar? – Comprobaciones de integridad, bases de referencia conocidas, telemetría independiente, reconstrucción de procedencia

9. Estrategia de Contención

El mantenimiento limita el daño preservando la seguridad, las operaciones, las pruebas y las opciones de recuperación.

“Escoge las acciones a través de objetivos explícitos, impactos, autoridad y verificación.” / Español

Figure 4. Containment decision

9.1 Opciones

- Punto final de aislamiento, red de segmentos, indicador de bloques, cuenta desactivada, sesiones de revocación, tokens/keys rotatorios, eliminar la exposición pública, detener la integración, restringir datos, detener el despliegue, desactivar o cerrar.
- La contención a corto plazo puede ser rápida y temporal; la contención a largo plazo apoya una operación más segura hasta la erradicación.
- Usar la acción organizada o coordinada cuando pasos aislados alertarían a un atacante o romperían el servicio crítico.

9.2 Decision record

- El objetivo y la amenaza son limitados.
- Servicio de negocios afectado, seguridad, cliente, evidencia, privacidad y impacto de recuperación.
- Alternativas consideradas y la razón seleccionada.
- Aprover, ejecutor, tiempo, comandos/cambio de entrada, pruebas antes y después, devolución y verificación.
- Exposición residual y siguiente punto de decisión.

10. Erradicación y rehabilitación

La erradicación elimina la causa, el acceso de los atacantes, la persistencia, los cambios inseguros y las debilidades conexas.

10.1 Erradicación

- Eliminar archivos maliciosos, procesos, tareas, servicios, cuentas, aplicaciones, reglas, caminos de acceso e infraestructura.
- Revocar sesiones y fichas; rotar contraseñas expuestas, claves, certificados, secretos, códigos de recuperación y relaciones de confianza en un orden seguro.
- Capturar o mitigar vulnerabilidades explotadas; endurecer la configuración; cerrar los servicios expuestos; corregir las vías de identidad y de red.
- Reconstruido de fuentes de confianza cuando la integridad no puede ser demostrada.
- Buscar toda la población potencial para la misma condición y validar ninguna persistencia alternativa permanece.
- Preserve evidence and separate remediation from proof; record every change.

TEN Causa principal contra punto de entrada: El punto de entrada explica cómo comenzó este incidente. Las causas raíz pueden incluir procesos, diseño, propiedad, visibilidad, habilidades, incentivos o debilidades de control que le permitieron tener éxito o persistir. | |.

11. Recuperación y regreso al servicio

Recovery restaura el servicio crítico a través de pasos controlados, verificados y monitorizados.

Jimg src="media/image5.png" style="width:6.15in;height:3.39605in" alt="La validación de la seguridad y la aceptación del negocio pertenecen dentro de la recuperación".

Gráfico 5 Retorno al servicio

11.1 Puertas de recuperación

- El mantenimiento es estable y la recuperación no volverá a conectarse a un compromiso activo.
- Fuente de restauración, construcción de oleoductos, copias de seguridad, credenciales, dependencias y vías de administración.
- Actualizaciones de seguridad necesarias, endurecimiento, rotación de identidad y monitoreo son activos.
- Se prueba la integridad de los datos, integridad, integridad, función de aplicación, interfaces, capacidad y resultados RTO/RPO.
- La reconexión es gradual; el aumento de la vigilancia tiene dueños claros y duración.
- Los propietarios de empresas y técnicos aprueban el regreso al servicio, con excepciones y riesgos residuales registrados.

11.2 Pruebas de recuperación

- Secuencia de recuperación y horarios reales.
- Versiones restauradas, fuentes, hashes/configuración, punto de datos y estado de dependencia.
- Resultados de seguridad, funcionalidad, conciliación de datos, rendimiento y aceptación de usuarios.
- RTO/RPO logró o perdió, causa, impacto, trabajo y acción correctiva.
- Mejores resultados de vigilancia y decisión de recurrencia.

12. Enseñanzas adquiridas y mejoras

La mejora convierte la experiencia en sistemas más seguros y mejores decisiones.

12.1 After-action process

- Realizar una revisión intachable pero responsable lo suficientemente pronto como para reconstruir los hechos y las decisiones.
- Construir el cronograma fáctico: señal, reconocimiento, escalada, decisiones, contención, erradicación, restauración, comunicación y cierre.
- Compare el rendimiento esperado frente al rendimiento real de personas, planes, datos, herramientas, proveedores, comunicaciones y recuperación.
- Identificar las condiciones de contribución y las causas sistémicas, no sólo los errores individuales.
- Asignar acciones específicas, propietarios, recursos, fechas basadas en el riesgo, protección provisional y medidas de éxito.
- Reprueba la capacidad fallida y las políticas de actualización, arquitectura, detecciones, libros de texto, contratos, capacitación, BIA, continuidad y planes de recuperación.

**** Acción débil** Silencioso**** |

|... | tención Mejorar la vigilancia | Añadir eventos de administración de proveedores de identidad al SIEM, alertar sobre nuevo papel privilegiado dentro de cinco minutos, y probar mensualmente | | Personal de formación | Ejecutar un ejercicio específico para la verificación de la identidad de los usuarios de los servicios y medir el tratamiento de fallos | para arreglar copias de seguridad Añadir copia diaria aislada para la base de datos Tier 1 y probar restaurar dentro de cuatro horas RTO trimestral | tención Plan de actualización | Añadir llamado tomador de decisiones alternativo, contacto fuera de banda, y paso de activación probado

13. Coordinación de las comunicaciones, jurídicas y reglamentarias

- La comunicación debe ser precisa, oportuna, autorizada, específica para el público y protegida.*

13.1 Reglas de funcionamiento

- Mantener una base de datos aprobada con tiempo, fuente, confianza, propietario y última actualización.
- Estatus operativo separado, análisis legal, hipótesis técnicas y mensajes públicos.
- Utilizar canales seguros apropiados para posibles compromisos y conservar los registros requeridos.
- Decir lo que se conoce, se desconoce, se hace, necesita del público, y la próxima vez de actualización.
- Rastrear los desencadenantes y relojes de notificación por ley, regulador, contrato, asegurador, cliente, empleado y jurisdicción.
- Coordinar legal, privacidad, comunicaciones, recursos humanos, seguridad, ejecutivos, proveedores, aseguradores y autoridades públicas.
- No especular, ocultar los hechos materiales, destruir los registros, o prometer el tiempo que los equipos no pueden soportar.

Audiencia | ... | Respuestas a las personas detenidas | Ejecutivos | Impacto empresarial, incertidumbre, opciones, recomendación, recursos, siguiente decisión | Lo que sucedió, acciones seguras, soporte, canal de reportaje, tiempo de actualización | | Clientes / partners | Servicio/datos afectados, acción protectora, soporte, actualizaciones verificadas | Silencioso Regulador / autoridad | Datos obligatorios, tiempo, alcance, impacto, medidas, cooperación | Public / media | Aprobado mensaje preciso, vocero, actualizaciones constantes

**** Nota legal:**** Los derechos de notificación y preservación son específicos para los hechos y la jurisdicción. Involucrar a un abogado calificado temprano; no utilice este manual como una determinación legal. | |

14. Evidencia digital y teoría forense

La preparación forense hace pruebas fiables, útiles, proporcionadas y disponibles cuando sea necesario.

■img src="media/image6.png" estilo="Ancho:6.15in; Altura:3.39605in" alt="Identidad documental, preservación, integridad, custodia, análisis y límites." /

Figura 6. Integridad y custodia de la evidencia

14.1 Registro de evidencia

- ID, descripción, sistema fuente/dispositivo/cuenta, colector, autoridad, zona hora/hora/hora, ubicación y razón.
- Método de recogida, herramienta/versión, configuración, copia original y de trabajo, hash criptográfico cuando sea apropiado, y protección de almacenamiento.

- Cada transferencia: de, a, fecha/hora, propósito, firmas o registro autenticado, y verificación de integridad.
- Análisis de pasos, consultas, transformaciones, normalización del tiempo, capturas de pantalla/exportaciones, hallazgos, explicación alternativa y limitación.
- Retención, retención legal, privacidad/minimización, registro de acceso, divulgación y eliminación aprobada.
- La seguridad y la autoridad* No acceda a cuentas personales, intercepte comunicaciones, colecte ampliamente o realice acciones invasivas sin autoridad adecuada. Siga las normas legales, políticas, privacidad, empleo y pruebas. | |.

15. Ataques Ransomware y Destructivos

El ransomware puede combinar el acceso, robo, extorsión, encriptación, destrucción y presión pública.

Prioridades inmediatas

- Proteger la vida y la seguridad; activar el liderazgo de incidentes y crisis.
- Aislar los sistemas y las redes afectados de manera coordinada; preservar la evidencia antes de la salida de energía cuando sea segura y útil.
- Infraestructura de identidad segura, vías administrativas, respaldos, hipervisores, consolas en la nube, herramientas remotas y sistemas de gestión.
- Determinar el alcance, la actividad del actor, la persistencia, el acceso/exfiltración de datos, la encriptación, el impacto empresarial y la exposición del proveedor.
- Usar comunicaciones fuera de banda y dispositivos secretos conocidos.
- Contratar a un abogado, un asegurador, personal cualificado y autoridades competentes en virtud de procedimientos aprobados.
- Priorizar la restauración de servicios críticos de confianza; validar copias de seguridad y no volver a conectarse a compromisos activos.

15.2 Decisión de pago

- El pago es una decisión legal, de seguridad, ética, sanciones, negocios y riesgo para el liderazgo autorizado, no un analista junior.
- El pago no garantiza desciframiento, eliminación, silencio o ausencia de ataques futuros.
- Preserve facts, authorities, alternatives, insurer conditions, and decision rationale; use qualified counsel and public authorities as appropriate.

16. Respuesta del incidente de Cloud and SaaS

La respuesta en voz alta depende de la telemetría de proveedores, responsabilidad compartida, control de inquilinos y acceso de soporte.

16.1 Investigación en la nube

- Auditoría, identidad, API, objeto, red, volumen de trabajo, base de datos, gestión clave, seguridad, facturación y registros de soporte antes de que expire la retención.
- Identificar inquilino, suscripción/proyecto/cuenta, región, recurso, identidad, papel, token, clave, automatización, aplicación y acción del proveedor.
- Revisar el plan de control y la actividad del plan de datos por separado.
- Pruebas instantáneas o exportadoras usando métodos compatibles; tiempo de proveedor de registros, identificadores, hashes y limitaciones.
- Escalada del proveedor de coordinación, solicitud legal, aviso de incidentes, subprocesador y derechos de responsabilidad compartida.

Contención en la nube

- Revocar sesiones y fichas, desactivar identidades comprometidas, rotar secretos/keys, restringir políticas y redes, cargas de trabajo cuarentena, detener la automatización insegura y preservar las vías de recuperación.
- Evite eliminar los recursos antes de que se entiendan las pruebas, la dependencia y las necesidades de devolución.
- Validar la infraestructura como código, imágenes, oleoductos, federación de identidad, registro y base de referencia inquilino antes de la reconstrucción.

17. Identidad y acceso privilegiado

El compromiso de la identidad puede cruzar puntos finales, servicios en la nube, proveedores y canales de recuperación.

17.1 Scope

- Contraseña, método MFA, sesiones, fichas de actualización/acceso, claves API, subvenciones OAuth, directores de servicios, certificados, métodos de recuperación, acceso delegado y roles privilegiados.
- Authentication success/failure, device, IP, location, impossible travel, registration, consent, role change, mailbox rule, application access, support reset, and audit-log change.
- Identidades relacionadas, dispositivos compartidos, herramientas de administración, sistemas federados, mostrador de ayuda, proveedores y cuentas de cristal.

17.2 Orden de recuperación segura

- Acceso administrativo de confianza seguro y control de identidad.
- Desactivar o restringir caminos comprometidos preservando las pruebas requeridas.
- Revocar sesiones/tokens y eliminar factores no autorizados, roles, aplicaciones, reglas y métodos de recuperación.
- Rotar secretos en orden de información sobre dependencia; verificar cuentas de servicio y automatización.
- Restaurar el acceso de los usuarios mediante una fuerte prueba de identidad; monitorear la recurrencia.
- Investigar cómo se evitaron los controles y probar el proceso corregido.

18. Incidentes de terceros y de intercambio de suministros

Un incidente del proveedor requiere hechos compartidos, responsabilidades, relojes de notificación y decisiones de recuperación.

18.1 Prepare

- Mantener los servicios actuales de proveedores, propietarios, datos, acceso, integraciones, cuartas partes, contactos de incidentes, términos de contrato y alternativas.
- Definir eventos reportables, tiempo de notificación y canal, datos mínimos, evidencia/cooperación, actualización, contención, recuperación, comunicación pública y derechos posteriores al incidente.
- Incluir proveedores críticos en ejercicios y pruebas de continuidad y salida.

18.2 Responder

- Confirme el producto afectado, versión, inquilino, región, datos, cuentas, integraciones, subprocesadores y periodo de tiempo.
- Reclamaciones separadas del proveedor de los hechos respaldados independientemente e incertidumbre récord.
- Proteger el acceso de la organización, claves, sesiones, integraciones, flujos de datos y clientes.
- Coordinar proveedor, equipos internos, clientes, autoridades, aseguradoras y otros proveedores afectados.
- Evaluar las opciones de riesgo, hallazgos, cumplimiento de contratos, concentración y salida/continuidad después de la recuperación.

19. Sistema de Gestión de la Continuidad Empresarial

A BCMS hace de la continuidad una capacidad de gestión gobernada, medida y mejora.

“Contexto, liderazgo, planificación, apoyo, operación, evaluación y trabajo de mejora como ciclo” (Contexto, liderazgo, planificación, apoyo, operación, evaluación y trabajo de mejora como ciclo.” /

Gráfico 7 Sistema de gestión de la continuidad de las operaciones

ISO 22301 area Silencioso ** Actividad práctica** |

|... || Contexto TENIENDO CUESTIONES internas/externas, partes interesadas, alcance y necesidades de continuidad | – Liderazgo permanente Política, roles, rendición de cuentas, integración y recursos – Planificar los riesgos/oportunidades, objetivos, cambios previstos – Apoyo a las personas, competencia, sensibilización, comunicación, información documentada TENIDA Operación | BIA, evaluación de riesgos, estrategia, procedimientos, ejercicios, evaluación Evaluación de la actuación profesional en la vida útil Vigilancia, medición, análisis, auditoría interna, examen de la gestión – Mejoramiento Ø Noconformidad, acción correctiva y mejora continua

tención **2024 enmienda climática:** ISO 22301:2019/Amd 1:2024 añade texto de acción climática a los requisitos de contexto del sistema de gestión. Las organizaciones deben considerar si el cambio climático es relevante y reconocer que las partes interesadas pueden tener requisitos relacionados con el clima. | |.

20. Estrategias y procedimientos continuos

Las estrategias de continuidad mantienen las actividades prioritarias en los niveles de impacto tolerable y mínimo de servicios.

Recurso

Personas – Entrenamiento cruzado, alternancias, trabajo remoto, equipos divididos, soporte contratado TEN ¿Pueden los suplentes entrenados realizar el proceso? –

instalaciones

– Tecnología

– Datos / registros

Proveedores – Proveedor alternativo, capacidad reservada, inventario, sustitución ¿Puede la entrega alternativa dentro de la tolerancia?

Utilidades / comunicaciones

tención Proceso Silencioso Priorización, servicio reducido, plan atrasado, trabajo manual alrededor

20.1 Procedimiento de continuidad

- Activación y autoridad.
- Producción prioritaria, nivel mínimo de servicio, duración máxima y meta de recuperación.

- Personas, contacto, ubicación, tecnología, información, proveedor y necesidades de seguridad.
- Trabajo paso a paso con controles, aprobaciones, registros, privacidad, reconciliación y recuperación atrasada.
- Comunicación de cliente/empleado y ritmo de estado.
- Criterios de regreso a lo normal, validación, aceptación del propietario y revisión posterior a la acción.

21. Planificación de la recuperación de desastres

Un plan de recuperación de desastres restaura la tecnología en orden de prioridad empresarial.

21.1 NIST SP 800-34 proceso de contingencia

- Elaborar la declaración de política de planificación para imprevistos.
- Realizar el análisis de impacto empresarial.
- Identificar controles preventivos.
- Cree estrategias de contingencia.
- Elaborar el plan de contingencia del sistema de información.
- Asegurar las pruebas, entrenamiento y ejercicios del plan.
- Asegurar el mantenimiento del plan.

21.2 DR plan content

- Alcance, suposiciones, activación, autoridades, contactos, proveedores, sitios, arquitecturas, dependencias y niveles de recuperación.
- Evaluación de daños, declaración, fallo, restauración, reconstrucción, validación, reconexión, retorno a la primaria y cierre.
- Manuales de sistema por sistema con prerrequisitos, credenciales, administración limpia, puntos de datos, interfaces, seguridad, pruebas y retroceso.
- Conflictos de recursos, capacidad, licencias, logística, comunicaciones y trabajos manuales.
- Actual RTO/RPO, excepciones, aceptación y pruebas de mejora.

22. Backups and Recovery Assurance

Los fondos requieren alcance protegido, separación, monitoreo, pruebas de restauración y administración confiable.

“El éxito de la copia no es prueba de recuperación; test de servicios completos e integridad de datos.” / Español

Figure 8. Backup-to-recovery assurance

22.1 Design

- Mapa de sistemas críticos, configuraciones, identidad, claves, código, datos de SaaS, registros y dependencias a objetivos de BIA.
- Utilice múltiples copias protegidas con separación adecuada, control de inmutabilidad/offline, encriptación, segregación de acceso, monitoreo y retención.
- Proteger consolas de respaldo, cuentas de servicio, eliminación, replicación, catálogos, credenciales de recuperación y redes de gestión.
- Evite replicar la corrupción o los cambios de atacante sin puntos de recuperación histórica utilizables.

22.2 Restore test

- Seleccione un sistema representativo y un punto de recuperación bajo un escenario aprobado.
- Utilizar personas autorizadas, administración limpia, cuaderno documentado y restauración aislada cuando proceda.
- Medir tiempo real y pérdida de datos; validar la integridad, integridad, seguridad, interfaces, rendimiento y uso de negocios.
- Insuficiencias récord y soluciones de trabajo; correcto y retestante.
- Informe si el servicio completo, no sólo un archivo, se refiere a RTO, RPO y requisitos mínimos de servicio.

23. Gestión de crisis y factores humanos

La gestión de la crisis coordina decisiones de alto impacto cuando la información es incompleta y importa el tiempo.

23.1 Liderazgo

- Establecer objetivos de seguridad, servicio, legal, cliente, evidencia y recuperación en orden prioritario.
- Mantener un cuadro operativo común: hechos, incertidumbre, efectos empresariales, decisiones, acciones, recursos y próxima actualización.

- Assign one decision owner and one action owner; record rationale and time.
- Usar breves reuniones informativas y canales protegidos; controlar los rumores y las instrucciones contradictorias.
- Cuidado con la fatiga, cambio de turno, sesgo cognitivo, estrés, seguridad personal y necesidades familiares.
- Alivio del plan, comida, descanso, transporte, accesibilidad, apoyo mental-salud y respetuosos beneficios.

Elemento de sufrimiento |

|... | ¿Qué ha cambiado desde la última actualización? ¿Quién o qué es afectado ahora y con el tiempo? ¿Qué hecho perdido podría cambiar la decisión? tención Objetivos | ¿Qué resultados importan en el próximo período operativo? Silencioso ¿Cuáles son los beneficios, los daños, las dependencias y la reversibilidad? TENCIÓN ANTERIOR ¿Quién decide por cuándo? ¿Quién hace qué, por cuándo, con qué evidencia? — Comunicación | ¿Quién necesita qué mensaje verificado y cuándo? |

24. Ejercicios, entrenamiento y mantenimiento de planes

Los ejercicios deben evaluar la capacidad, no recompensar un rendimiento ensayado.

'img src="media/image9.png" style="width:6.15in;height:3.39605in" alt="Definir objetivos y capturar evidencia observable antes de asignar acción correctiva".

Gráfico 9 Ciclo de ejercicio y mejora

Tipo de ejercicio

— Lista de verificación / prueba de acceso — Validar registros, contactos, acceso y sencillos pasos — tención Tabletop — Discuss decisions, roles, información y coordinación usando un escenario | — Simulación | Opera equipos y comunicaciones en un entorno controlado realista | Prueba de recuperación técnica | Restaurar, reconstruir, fallar, validar y medir la tecnología | Prueba de paralelo | Corre capacidad de recuperación sin reemplazar la producción tención Interrupción completa — Cambio de servicio real bajo una autoridad controlada firmemente; mayor riesgo — Ejercicio de equipo púrpura TENENCIA Ataque, detección, respuesta y mejora de forma colaborativa

24.1 After-action evidence

- Objetivo y capacidad probada, escenario, hipótesis, participantes, observadores, reglas y controles de seguridad.
- Medidas esperadas y criterios de éxito mensurables.
- Plazo real, decisiones, comunicaciones, uso de herramientas/plan, resultados de recuperación y limitaciones.

- Fortalezas, lagunas, causas profundas y que aportan, riesgo, propietarios, fechas, controles provisionales y pruebas.

25. Mapping de Cumplimiento, Testing de Evidencia y Métricas

Frameworks superpone, pero la evidencia debe ser probada contra el requisito exacto aplicable.

Fuente | . | | NIST SP 800-61 Rev. 3 | CSF Comunidad Perfil para respuesta a incidentes a nivel de toda la organización | NIST SP 800-34 Rev. 1 Update 1 – Proceso de planificación de contingencias del sistema de información federal TEN Older pero actual NIST final; adaptarse fuera del uso federal | | ISO 22301:2019 + Amd 1:2024 | Requisitos para un sistema de gestión de la continuidad de las operaciones confidencialidad ISO 22313:2020 guía permanente para usar ISO 22301 | no es la certificación | SOC 2 | Disponibilidad, seguridad, confidencialidad, privacidad, compromisos de procesamiento y controles | Revisión exacta informe alcance, período, pruebas, excepciones | | ISO/IEC 27001:2022 | Gestión de incidentes, preparación de continuidad, copia de seguridad, registro de datos, proveedores TEN PCI DSS v4.0.1 ANTE Respuesta de incidentes, pruebas, proveedores de servicios, respaldos y controles relacionados con la recuperación TEN Validate exact cardholder-data environment scope ANTE | HIPAA | Plan de Contingencia, procedimientos de incidentes, backup, DR, operación de emergencia | La aplicabilidad y la implementación legales requieren análisis específico de hechos TEN GDPR | Seguridad, evaluación de incumplimiento/notificación, cooperación con los procesadores, resiliencia/restoración TENIDOS Funciones legales, riesgo, tiempo, jurisdicción requieren asesoramiento ANTERI

25.1 Test de evidencia

- Definir criterios, alcance, período, sistemas, procesos, proveedores y exclusiones.
- Validar la población completa: incidentes, alertas, planes, pruebas, recuperaciones, proveedores, respaldos, sistemas o acciones.
- Inspeccione el diseño y las pruebas operativas; la investigación por sí sola es débil.
- Muestra defensivamente o prueba a toda la población; método de registro y limitaciones.
- Evaluar excepciones, patrones, impacto, causa, controles compensatorios y riesgo residual.
- Seguimiento de la acción correctiva y prueba independiente antes del cierre.

**** Silencioso****

tiempo para detectar el tiempo de inactividad desde el inicio del evento/primera evidencia para la detección de tiempo de inicio puede ser incierto | Tiempo medio para contener la detección/activación de tóxicos para la contención verificada. | – Recuperación del objetivo logro – Tests/incidentes reunión RTO y RPO ÷ pruebas/incidentes en el telescopio – Definir el éxito del servicio completo Ø escenarios críticos aprobados ÷ escenarios críticos aprobado – La discusión no es una prueba técnica – Acción correctiva edad tención Días abiertos por

severidad y propietario – Closure requiere retest – Respaldo restaurar el éxito | Exitoso representante restaura ÷ pruebas programadas – Restauración del archivo puede no probar la recuperación del servicio Repetición de incidentes de incidir en la vida Repetir incidentes relacionados con la misma causa no corregida

26. Open-Source Tools

Las herramientas de código abierto apoyan la gestión de casos, pruebas, detección, investigación, automatización y presentación de informes.

Tool** Silencioso**

|... | TEN TheHive | Gestión de casos y colaboración con incidentes | Cortex | Acciones de análisis y respuesta – MISP | -información compartir y correlación TEN Wazuh TENRI Endpoint monitoring, log analysis, file integrity, and alerts | | Velociraptor | Visibilidad y colección de respuesta a incidentes – Volatilidad 3 – Memoria forense Ø Autopsia permanente Disk y análisis forense del sistema de archivos | Timesketch | tención Plaso / log2timeline tención Extracción de Timeline de artefactos forenses Osquery | Endpoint estado y amenazas búsquedas | Zeek – Seguridad de la red telemetría y metadatos de protocolo | Suricata Silencioso Red de detección y prevención de intrusiones TEN YARA | Patrón que coincide con los archivos y la memoria – Sigma – Normas de registro portátiles | DFIR-IRIS | Respuesta del incidente y gestión del caso de investigación TEN GRR Respuesta Rápida TENIDA Forenses en directo a escala de punta Orquestación y automatización de seguridad | – OpenSearch – Búsqueda, análisis, paneles y registros de seguridad

TEN Authorization and evidence safety: Utilice herramientas sólo en sistemas, redes, cuentas, repositorios y datos que posee o tiene autoridad escrita para examinar. Laboratorios de aislamiento, proteger evidencia, minimizar datos personales, acciones de registro y nunca dejar que la automatización realice pasos destructivos sin salvaguardias aprobadas. | Respuesta

26.1 TheHive

Objetivo: Gestión de casos y colaboración con incidentes. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un caso de laboratorio, definir tareas y severidad, añadir observables sintéticos, registrar decisiones, proteger permisos y cerrar sólo después de su revisión.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.2 Cortex

Objetivo: Medidas de análisis y respuesta observables. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Conectar sólo analizadores aprobados en un laboratorio, enviar observables sintéticos, validar resultados, restringir los equipos de respuesta y retener registros de acción.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.3 MISP

Propósito: Intercambio de información sobre amenazas y correlación. Proyecto oficial: [ejecutado]I](<https://www.misp-project.org/>)

Inicio rápido seguro: Crear un evento de laboratorio privado, añadir indicadores sintéticos con marcas de contexto y manejo, correlacionar, exportar sólo datos aprobados y expirar indicadores de estable.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.4 Wazuh

Propósito: Supervisión de puntos finales, análisis de registros, integridad de archivos y alertas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un punto final de laboratorio, generar un evento inofensivo, confirmar la recogida y alerta, investigar, documentar la cobertura y sintonizar cuidadosamente.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.5 Velociraptor

Finalidad: visibilidad de punto final y colección de respuesta a incidentes. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un laboratorio autorizado aislado, recoger un artefacto estrecho, registrar el alcance y el acceso, verificar los resultados y eliminar los datos de laboratorio retenidos según la política.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.6 Volatilidad 3

Propósito: Memoria forense. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Analizar una imagen de memoria de entrenamiento legalmente obtenida, grabar hashes y versión de herramienta, ejecutar plugins enfocados, validar hallazgos, y preservar notas.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.7 Autopsia

Objetivo: Análisis forense de disco y sistema de archivos. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un caso desde una imagen de entrenamiento, verificar el hash de la fuente, usar análisis solo lectura, etiqueta evidencia, exportar un informe y asegurar el caso.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.8 Timesketch

Propósito: Líneas de tiempo forense colaborativas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Importar un cronograma sintético, etiquetar eventos clave, hipótesis de búsqueda, conclusiones de analista récord e incertidumbre, y acceso de control.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.9 Plaso / log2timeline

Propósito: Extracción temporal de artefactos forenses. Proyecto oficial: [\[ejecutado\]o\(https://plaso.readthedocs.io/\)](https://plaso.readthedocs.io/)

Comenzar rápido seguro: Procesar una imagen de entrenamiento o conjunto de artefactos aprobados, opciones de parser de documentos y zona horaria, exportar un cronograma y validar eventos clave.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.10 osquery

Propósito: Endpoint estado y búsquedas de amenazas. Proyecto oficial: (<https://www.osquery.io/>)

Comenzar rápido seguro: Ejecutar consultas sólo de lectura en un laboratorio, documentar la consulta y la población, comparar puntos finales, validar anomalías y evitar la colección incontrolada.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.11 Zeek

Propósito: Telemetría de seguridad de red y metadatos de protocolo. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un sensor de laboratorio o una captura de paquetes aprobada, generar tráfico seguro, inspeccionar registros, construir una línea de tiempo y documentar límites de tráfico cifrados.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.12 Suricata

Objetivo: detección y prevención de intrusiones en red. Proyecto oficial: [Seguido] (<https://suricata.io/>)

Inicio rápido seguro: Use una interfaz de laboratorio, actualice las reglas aprobadas, genere tráfico de prueba, valide alertas, sintonice con control de cambio y mantenga versiones.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.13 YARA

Propósito: Patrón que coincide con archivos y memoria. Proyecto oficial: (<https://virustotal.github.io/yara/>)

Inicio rápido seguro: Prueba una regla estrecha contra muestras inofensivas, fuente de reglas de documentos y falsos positivos, revisión por pares, y escanear sólo datos autorizados.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista

validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.14 Sigma

Propósito: Reglas de detección de troncos portátiles. Proyecto oficial: (<https://sigmahq.io/>)

Inicio rápido seguro: Seleccione una regla, mapee a los campos disponibles, convierta para una plataforma de laboratorio, prueba con registros sintéticos, sintonía, revisión de pares y versiones de pista.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.15 DFIR-IRIS

Propósito: Respuesta de incidentes y gestión de casos de investigación. Proyecto oficial: (<https://dfir-iris.org/>)

Comenzar rápido seguro: Crear un caso ficticio, asignar tareas, registrar plazos y pruebas, restringir roles, generar un informe y probar respaldo/exportación.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.16 GRR Rapid Response

Objetivo: Forenses remotos en directo a escala de punta. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Implementar sólo en un entorno autorizado aislado, aprobar un flujo de recogida estrecho, verificar los registros de auditoría y controlar los resultados retenidos.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.17 Shuffle

Propósito: orquestación y automatización de seguridad. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Construir un flujo de trabajo de laboratorio con entradas inofensivas y puertas de aprobación, probar caminos de falla, registrar cada acción y mantener las acciones destructivas desactivadas.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista

validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.18 OpenSearch

Propósito: Búsqueda, análisis, paneles y registros de seguridad. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Ingerir troncos sintéticos, normalizar el tiempo y los campos, crear una consulta enfocada y un panel de control, restringir el acceso y la retención de documentos.

Evidencia: autoridad escrita y alcance, identidad de origen, zona de fecha/hora/hora, herramienta y versión, configuración/query, hashes where appropriate, raw result, analista validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

27. Manual de resiliencia para gerentes

Los administradores crean resiliencia estableciendo autoridad, preparando financiación, desafiando pruebas y eliminando bloqueadores.

Area | Pregunta principal | ...

- | – Gobernanza permanente ¿Está claro la autoridad, los suplentes, la gravedad, la escalada, el gasto y los cambios de emergencia? | No toma la decisión después de horas ¿Se prueban inventarios, registros, contactos, acceso, herramientas, comunicaciones y recursos de recuperación limpios? tención Plan existe pero el acceso falla | Respuesta ¿Se controlan hechos, incertidumbre, objetivos, acciones, pruebas y próxima actualización? – Equipos conflictivos o decisiones indocumentadas | ¿Puede continuar la producción crítica dentro de un impacto tolerable? – Workaround ignora seguridad, privacidad o reconciliación ¿Pueden los servicios completos satisfacer RTO/RPO probados de fuentes de confianza? | Respaldo éxito reportado sin restaurar la prueba | Proveedores | ¿Se ejercen contactos críticos, deberes, dependencias y alternativas? | Un proveedor es una dependencia común oculta TENEDAD ANTE ¿Se gestionan cambios, despidos, descanso, seguridad y tensión psicológica? Respuestas agotadas que toman decisiones críticas Ø Mejoras en la vida ¿Se financian, poseen, miden y se prueban acciones severas? | La misma brecha aparece en ejercicios/incidentes posteriores

27.1 Cuestiones ejecutivas

- ¿Cuál es el impacto actual del negocio y la seguridad?
- ¿Qué hechos apoyan la conclusión y qué sigue siendo incierto?
- ¿Cuáles son las dos decisiones siguientes, quién las posee, y cuándo son necesarias?
- ¿Qué acción podría causar daño irreversible o destruir pruebas?
- ¿Pueden continuar los servicios críticos, y por cuánto tiempo?

- ¿Se están siguiendo las obligaciones legales, de privacidad, contractuales, aseguradoras, clientes y de autoridad?
- ¿Qué recursos o opción comercial está bloqueando la contención o recuperación?
- ¿Cómo verificaremos la recuperación e impediremos la recurrencia?

28. Junior Analyst Career Guide and Portfolio Lab

Los analistas universitarios ganan confianza a través de registros de casos disciplinados, manipulación de pruebas, curiosidad técnica y escritura clara.

■img src="media/image10.png" style="width:6.15in;height:3.39605in" alt="Build safe practice from frameworks to evidence, cases, workpapers, and interview stories." /

Gráfico 10 Ruta del analista de resiliencia

28.1 Funciones comunes

- Analista de respuesta de incidentes junior
- SOC Analista
- Análisis de Operaciones de Seguridad Cibernética
- DFIR Analyst (junior)
- Analista de continuidad de negocios
- Analista de Recuperación de Desastres
- Analista de Resiliencia Cibernética
- GRC / Analista de Riesgo de TI

28.2 Típico trabajo

- Alertas válidas y enriquecedoras; casos precisos abiertos; hechos separados de supuestos.
- Construir plazos, alcance poblaciones afectadas, preservar pruebas aprobadas y registrar consultas/acciones.
- Siga los libros de juego, escalar la gravedad, coordinar tareas y preparar resúmenes de estado.
- Control de contención, remediación, evidencia de recuperación, acciones correctivas y pruebas.
- Mantener contactos, planes, datos de BIA/dependencia, registros de recuperación, registros de ejercicios y métricas.

- Utilizar herramientas de código abierto autorizadas en un laboratorio y explicar limitaciones.

28.3 Fictional portfolio lab

- Crear una organización ficticia de 80 personas con correo electrónico en la nube, endpoints, SaaS CRM, aplicación web, datos de clientes, proveedores y un proceso crítico de facturación.
- Escriba un BIA con impacto a lo largo del tiempo, dependencias, MTPD, RTO, RPO y nivel mínimo de servicio.
- Construir la política de incidentes, RACI, matriz de gravedad, contactos, comunicaciones, ransomware, identidad, nube y manuales de proveedores.
- Usar registros sintéticos para investigar una cuenta comprometida de ficción; crear una línea de tiempo, memo de alcance, registro de contención y actualización de gerente.
- Analizar un disco de entrenamiento legal o imagen de memoria con Autopsia o Volatilidad; fuente de documentos, hash, método, hallazgos y límites.
- Crear un cuaderno de DR y realizar una prueba de restauración segura con fechas y validación de datos reales.
- Ejecutar una mesa y elaborar un informe posterior a la acción con mejoras verificadas.
- Publicar sólo artefactos ficticios sanitarios y afirmar que el trabajo es educativo, no una investigación real o certificación.

29. Plan de treinta días y preparación de entrevistas

Un mes centrado puede crear capacidad de incidencia y resiliencia a nivel de entrada.

Días

1–3 TENIDOS conceptos de IR/BC/DR/crisis y modelo NIST actual

tención 4–6 tención de riesgo, BIA, dependencias, RTO/RPO | 7–9 | Preparación, registro de datos, contactos, playbooks ANTE Lecciones de lectura y dos playbooks ANTE | 10–12 Silencioso Detección, triage, severidad, casos – Caso de alerta sintético | TEN 13–15 | Investigación, cronología, pruebas | Timeline y antecedentes de pruebas tención, erradicación, recuperación permanente Documentos de trabajo sobre la decisión y la recuperación | 19–21 | Continuidad, DR, restauración de respaldo Silencioso procedimiento de continuidad y restauración de la prueba | 22–24 | Nube, identidad, ransomware, proveedores tención 25–27 Silencioso Ejercicio y revisión después de la acción TEN 28–30 TENIDA Metrics, portafolio, entrevistas ANTERI Dashboard y cinco historias de STAR

29.2 ¿Cuál es la diferencia entre IR, BC y DR?

IR administra incidentes cibernéticos, BC mantiene productos comerciales críticos durante la interrupción, y DR restaura tecnología y datos. Coordinan pero tienen diferentes objetivos.

29.3 ¿Qué es NIST SP 800-61 Rev. 3?

La guía de respuesta a incidentes NIST actual, finalizada en 2025, expresada como un perfil comunitario CSF 2.0 a través de Govern, Identificar, Proteger, Detectar, Responder y Recover.

29.4 RTO versus RPO?

RTO es el tiempo objetivo para restaurar; RPO es la pérdida máxima tolerable de datos medida en el tiempo.

29.5 ¿Cómo se recorta un incidente?

Validar la señal, evaluar los efectos funcionales e informativos, la recuperabilidad, la amenaza, el alcance, las obligaciones y la incertidumbre, y luego asignar la gravedad y la escalada según criterios aprobados.

29.6 ¿Qué hace que las pruebas sean fiables?

Fuente conocida, recogida repetible autorizada, integridad preservada, horarios, molestias cuando proceda, custodia, almacenamiento protegido y limitaciones documentadas.

29.7 ¿Cuándo se completa la recuperación?

Cuando la eliminación de amenazas es estable, la restauración de confianza y las pruebas de seguridad/funcional/data tienen éxito, la vigilancia es activa y los propietarios de negocios y técnicos autorizados aceptan el regreso al servicio.

29.8 ¿Cómo cierras una mejora?

Implementar la acción específica y reprueba la capacidad fallida contra criterios de éxito definidos.

29.9 ¿Qué debe evitar un analista junior?

Acceso no autorizado, acción destructiva, conclusiones no apoyadas, cambios de evidencia original, ocultando incertidumbre o resultados legales prometedores.

29.10 Preguntas para hacer al empleador

- ¿Qué escenarios de incidencia y resiliencia importan más?
- ¿Cómo se maneja la severidad, el mando, la escalada después de las horas y la aceptación empresarial?
- ¿Qué herramientas de telemetría, caso, forense, continuidad y recuperación están aprobadas?

- ¿Con qué frecuencia se realizan restauraciones críticas e incidentes de proveedores?
- ¿Cómo se revisan las acciones menores y se protegen las pruebas?
- ¿Cómo sería el éxito en los primeros 90 días?

30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos clave, índice de sujeto y fuentes oficiales*.

30.1 Registro de casos de incidentes

|** | |. | “Principio/comandante/severidad” “Prigger” / detectado/known start ·
 “Datos/asunciones/hipotheses” sobre la vida
 “Afectados y potenciales alcances” “La vida empresarial/data/seguridad” tuvo un impacto sobre la seguridad. Evidencia/timeline/custody |
 “Primeros objetivos/decisiones/actions” “Contenimiento/eradicación en la vida” “La recuperación/validación/aceptancia de la vida” “La comunicación/obligaciones en la vida”
 Lecciones/acción/retestigos sobre la vida

30.2 BIA y registro de continuidad

|** | |... | | Producto/servicio/proceso/procesador |
 La salida mínima aceptable es válida para siempre. Impacto de la vida por el tiempo / MTPD |
 | RTO / RPO |
 “Personas/facilidad/tecnología” Los datos/dependencias de la seguridad de la vida siguen adelante. La estrategia de continuidad y el trabajo en torno a la vida
 “La Activación/comunicación en la vida” “Vuelva/reconciliación” Test/result/improvementar la vida

30.3 Registro de evidencia y cadena de custodia

|** | |... | | EL ID/descripción / fuente |
 La autoridad y el propósito de la vida han sido incapaces. | RECIBOR/date / time zone TEN
 | | Método/herramienta / versión |
 | Original hash/working copy · | | Almacenamiento/access/privacy |
 “Transferencia de/a/a propósito” “Análisis/resulto/limitaciones” “Retención de la vida”
 Repaso/disposición de la vida

30.4 Registro de ejercicio y acción correctiva

|** | |... | | Objetivo/capacidad | “Scenario/asunciones/seguridad” Los participantes/observadores insistieron en la vida
 Los criterios de éxito esperados son válidos. TENIENDO el tiempo real/decisiones |
 “Strengths/gaps/evidencia” | Cause/risk / interim control | “Actuación/proprietario/ fecha límite” Retest/evidence / result remain
 · Management review ·

30.5 Glosario

|** | |... | | evento Adverso | Una ocurrencia que puede tener una consecuencia negativa. TEN BCMS | Sistema de gestión de continuidad de las operaciones. TEN BIA | Análisis de impacto empresarial. TEN continuidad de las operaciones ANTERI Capability to continue delivery of products and services at acceptable capacity during disruption. – Cadena de custodia | Control documentado y transferencia de antecedentes de evidencia. TENIENDO | Acción para limitar la propagación o el impacto de incidentes. tención Gestión de crisis | Liderazgo y coordinación de situaciones de alto impacto e incertidumbre. | – Recuperación de desastres | Restauración de tecnología, datos y infraestructura de apoyo después de la perturbación. | Erradicación de la vida útil Eliminación de causa, persistencia, cambios inseguros y debilidades conexas. | tención Incident Silencioso que pone en peligro la confidencialidad, integridad, disponibilidad o viola la política de seguridad; utilice la definición aprobada de la organización. | | MTPD / MAO | Período máximo tolerable de perturbación / salida máxima aceptable. tención Playbook – Pasos de respuesta centrados en el escenario, decisiones, autoridad y evidencia. Silencioso Recuperación Silencioso Restauración y verificación del servicio y los controles. | RPO | Pérdida máxima tolerable de datos medida en el tiempo. | RTO | Tiempo para restaurar una actividad o recurso. tención Ejercicio en la mesa | Evaluación basada en el debate utilizando un escenario y preguntas de decisión. |

30.6 Subject index

Subjeto** | |... | – Respaldos Silencioso 22 | BIA | 3, 20 | para la continuidad de las operaciones | Silenciosos incidentes en la nube | en la comunicación | | | | – Gestión de crisis Silencioso Detección/triage | 6-7 | Pruebas digitales | | para la recuperación ante desastres | Silencioso Ejercicios Silenciosos incidentes de identidad Silenciosos en la investigación Silencioso analista junior lecciones aprendidas Silencioso Silencioso TENIDA métricas/cumplimiento tención NIST SP 800-61 Rev. 3 | 4, 25 | | Herramientas de código abierto | 26 | | | . Silencioso de recuperación | RTO / RPO | 3, 21-22 Silenciosos incidentes ocurridos en los proveedores

30.7 Referencias oficiales

- [indicau]NIST SP 800-61 Rev. 3 — Recomendaciones de respuesta de incidentes realizadas/u contacto](<https://csrc.nist.gov/pubs/sp/800/61/r3/final>)
- []](<https://csrc.nist.gov/projects/incident-response>)
- [Seguridad Ciberseguridad 2.0](#)
- [indicau]NIST SP 800-34 Rev. 1 Update 1 — Planeamiento de Contingencias realizados/u contacto](<https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final>)
- []](<https://www.cisa.gov/news-events/news/federal-government-cybersecurity-incident-and-vulnerability-response-playbooks>)
- ☐ (<https://www.cisa.gov/stopransomware/ransomware-guide>)
- []](<https://www.cisa.gov/ransomware-response-checklist>)
- ☐ []](<https://www.cisa.gov/resources-tools/services/cisa-tabletop-exercise-packages>)

- [Se indicará que el Plan de Respuesta de Incidentes se basará en el plan de acción de los incidentes] (<https://www.cisa.gov/resources-tools/resources/incident-response-plan-irp-basics>)
- [](<https://www.iso.org/standard/75106.html>)
- [](<https://www.iso.org/standard/88412.html>)
- [](<https://www.iso.org/standard/75107.html>)
- [indicau]ISO/TS 22317:2021 — Guía BIA realizada/u contacto](<https://www.iso.org/standard/79000.html>)
- [Seguridad de Incidencia de Incidencia de Seguridad Informática] Recursos de la Guía de Manejo de Incidentes obtenidos/u contactos](<https://csrc.nist.gov/Projects/incident-response/publications>)

Recordaje final: Las amenazas, la tecnología, las leyes, los contratos, las normas, las interpretaciones oficiales, los instrumentos, los contactos y las dependencias orgánicas cambian. Verificar las fuentes autoritativas actuales y los planes aprobados antes de un incidente real o decisión de recuperación. |

|. |